

Chapter 5 — Platform, Network, Workload, Build, and Supply-Chain Security

1. Document control

- Identifier: HAL-BVI-05
- Version: 1.0
- Status: Final
- Effective date: 2026-07-27

2. Purpose

Protect hosts, networks, workloads, execution boundaries, builds, artifacts, dependencies, and providers under compromised-component assumptions.

3. Scope

This chapter applies to HAL environments, components, repositories, operators, providers, Trust Domains, evidence, and external exchanges within the stated control applicability.

4. Authority and source requirements

- Book I: Decisions 17-25, 36-44, 47
- Book II: Chapters 2, 23, 28-33
- Book III: Chapters 2, 5, 7
- Book IV: CMP-13-14, CMP-20, CMP-22-26
- Book X: Chapters 6-9
- Book VIII governs verification and certification decisions; Book IX governs exact machine contracts.

5. Definitions and accountable roles

Book X terms retain their canonical meaning. Chapter roles: Platform Security Owner, Network Security Owner, Build Custodian, Dependency Owner, Workload Owner, Security Assessor.

6. Normative controls

VI-PLT-05-001 — Harden from declared baselines

Hosts, runtimes, containers, orchestrators, and managed services MUST conform to versioned hardening baselines with deviations recorded, time-bounded, monitored, and tested.

- Applicability: all platforms
- Responsible role: Platform Security Owner
- Enforcement: configuration assessment
- Required evidence: baseline conformance evidence
- Severity: High
- Exception authority: Security and Trust Executive
- Protection objective: Protect HAL

VI-PLT-05-002 — Segment by trust and authority

Network and workload paths MUST be allow-listed by authenticated identity, declared need, Trust Domain, data class, and permitted operation; network location MUST NOT establish trust.

- Applicability: all communications
- Responsible role: Network Security Owner
- Enforcement: policy-as-code and flow tests
- Required evidence: segmentation evidence
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-PLT-05-003 — Isolate workloads

Workloads MUST have separate identities, least resources, restricted host access, read-only roots where practical, controlled egress, bounded persistence, and containment against neighboring compromise.

- Applicability: all workloads
- Responsible role: Workload Owner
- Enforcement: admission and runtime policy
- Required evidence: workload attestation
- Severity: High
- Exception authority: Platform Security Owner
- Protection objective: Protect HAL

VI-PLT-05-004 — Build reproducibly

Release artifacts MUST be produced by isolated, pinned, reviewable builds with protected inputs, deterministic steps where feasible, independent verification, and no developer workstation as release authority.

- Applicability: release builds
- Responsible role: Build Custodian
- Enforcement: reproducible build gate
- Required evidence: build manifest and comparison
- Severity: Critical
- Exception authority: None
- Protection objective: Protect HAL

VI-PLT-05-005 — Sign and verify provenance

Artifacts, dependencies, policies, configurations, and critical data packages MUST carry verifiable provenance and integrity; failed or unknown provenance MUST block protected use.

- Applicability: admitted artifacts
- Responsible role: Build Custodian
- Enforcement: admission verification
- Required evidence: provenance record
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-PLT-05-006 — Maintain dependency inventories

Every deployable unit **MUST** have a current transitive inventory, ownership, source, version, license disposition, integrity, support status, known risk, and replacement path.

- Applicability: all dependencies
- Responsible role: Dependency Owner
- Enforcement: SBOM and policy gate
- Required evidence: SBOM and disposition
- Severity: High
- Exception authority: Risk Steward
- Protection objective: Protect HAL

VI-PLT-05-007 — Assume component compromise

Architecture and operations **MUST** constrain a compromised node, provider, dependency, model, adapter, or service from acquiring authority, mutating foreign authoritative state, suppressing audit, or escaping its domain.

- Applicability: all components
- Responsible role: Security Assessor
- Enforcement: adversarial containment tests
- Required evidence: compromise containment report
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-PLT-05-008 — Control external build services

External builders, registries, repositories, and vendors **MUST** be separate Trust Domains with explicit permitted exchanges, evidence, revocation paths, and no implicit constitutional trust.

- Applicability: external supply chain
- Responsible role: Build Custodian
- Enforcement: third-party and exchange review
- Required evidence: external service assessment
- Severity: Critical
- Exception authority: Security and Trust Executive
- Protection objective: Both

7. Required operating practices

Control Owners **MUST** maintain procedures, training, tools, dependencies, evidence paths, response actions, and succession coverage necessary to operate each applicable control.

8. Prohibited practices

- Treating trust, identity, credentials, compliance, or certification as Authority.
- Bypassing the authoritative component owner, Constitutional Kernel, Authority Service, Constitutional Firewall, or Evidence Service.
- Using undocumented, permanent, self-approved, or silently renewed exceptions.
- Replacing required evidence with assertion, dashboard color, ticket status, or unverified third-party claims.

9. Required evidence

Evidence MUST identify the control, target, version, environment, actor, time and confidence, source, method, outcome, exceptions, integrity, classification, retention, and linked incident or remediation.

10. Automated enforcement

Controls marked automated MUST deny, quarantine, expire, alert, or constrain according to the stated failure behavior. Automation MUST expose inputs, versions, decision logic, failures, and overrides.

11. Human review

A qualified reviewer MUST evaluate proportionality, constitutional restraint, privacy, trust assumptions, evidence sufficiency, conflicts of interest, and residual risk at the control's declared cadence and after material change.

12. Exceptions and failure consequences

Constitutional invariants are not waivable. Missing or expired exceptions MUST fail closed for protected actions or enter the safest evidence-preserving restricted state. Critical violations require incident evaluation and affected-assurance review.

13. Security, privacy, trust, and reliability considerations

Implementations MUST minimize sensitive evidence, preserve recoverability, constrain compromised components, keep trust separate from permission, and maintain auditable denial and recovery paths.

14. Verification method and metrics

Verify by catalog completeness checks, policy and configuration tests, adversarial negative cases, sampled evidence reconstruction, incident and recovery exercises, and independent review. Metrics MUST measure outcomes and control effectiveness rather than activity alone.

15. Traceability

- Book I: Decisions 17-25, 36-44, 47
- Book II: Chapters 2, 23, 28-33
- Book III: Chapters 2, 5, 7
- Book IV: CMP-13-14, CMP-20, CMP-22-26
- Book X: Chapters 6-9

16. Examples and anti-patterns

Conforming example: the responsible role records a scoped decision, machine enforcement, minimized evidence, independent verification, expiry, and a tested failure path.

Anti-pattern: a team treats a credential with favorable Trust evidence, passing scan, active certificate, or urgent incident as Permission to bypass Authority or expand Treaty scope.

17. Review findings, Owner Review, and completion

Constitutional, architecture, enforceability, security, privacy, trust, reliability, usability, automation, duplication, and burden reviews found no unresolved material defect. No Owner Review item is required. Status: Complete.